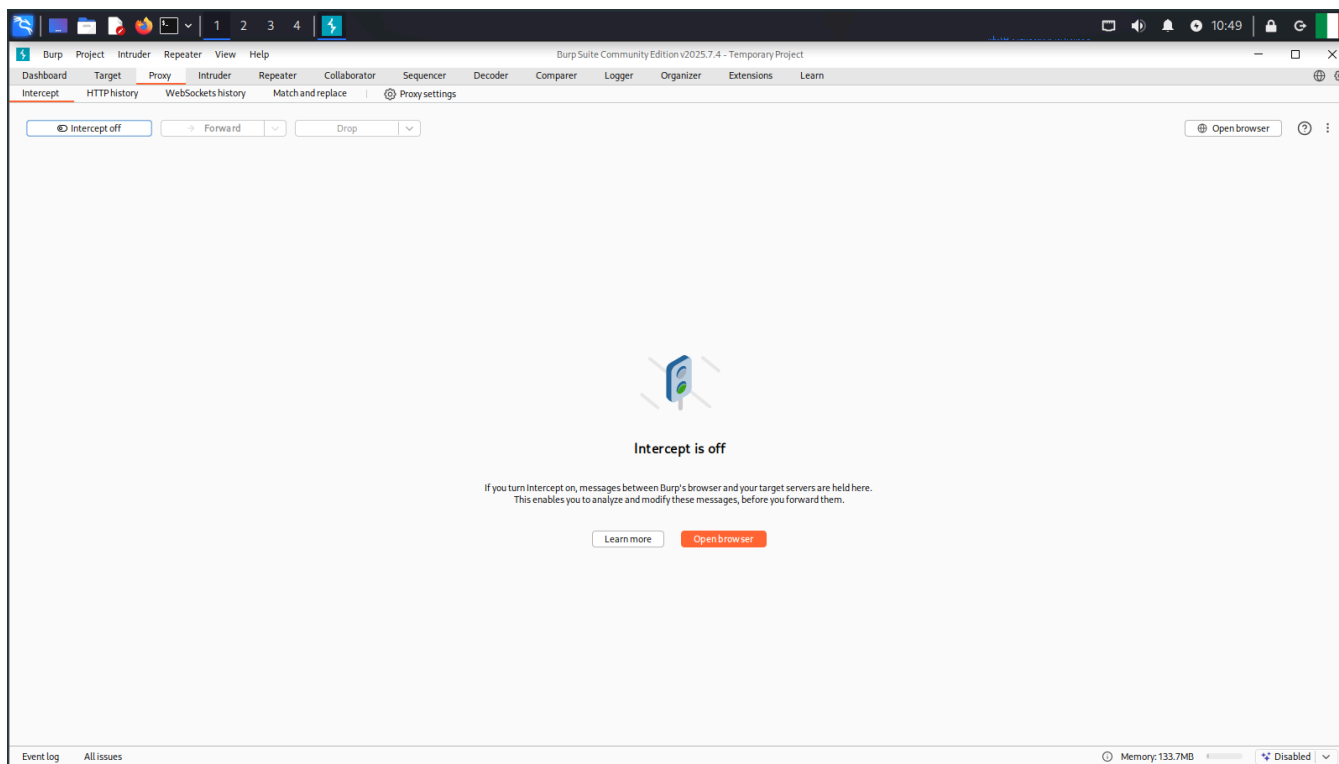


W8D1 - Introduzione a BurpSuite

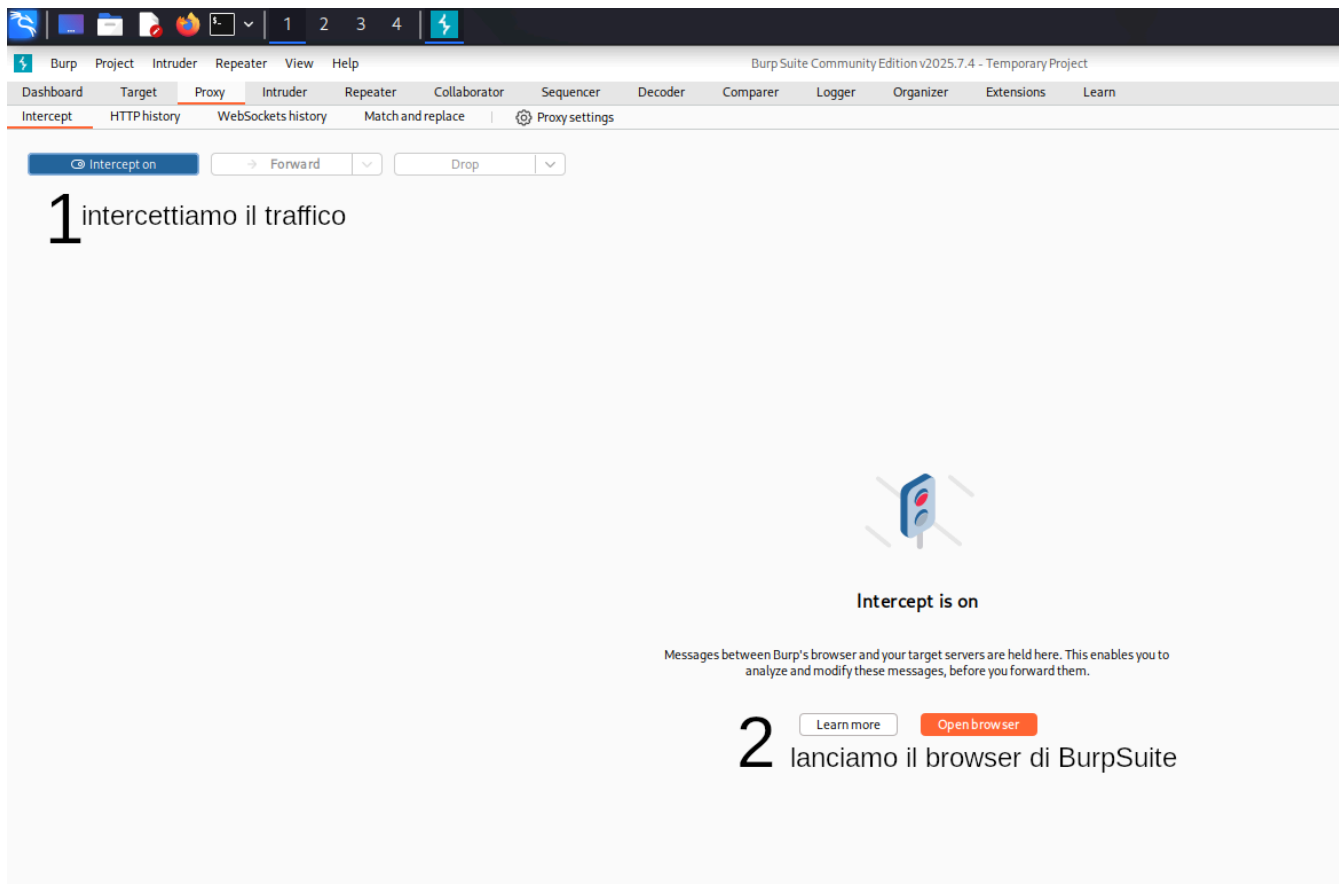
Oggi ci occuperemo di introdurre [BurpSuite](#), un software proxy che permette di ispezionare e manipolare il traffico da e verso un browser per studiarne eventuali vulnerabilità.

Avviamo Burp

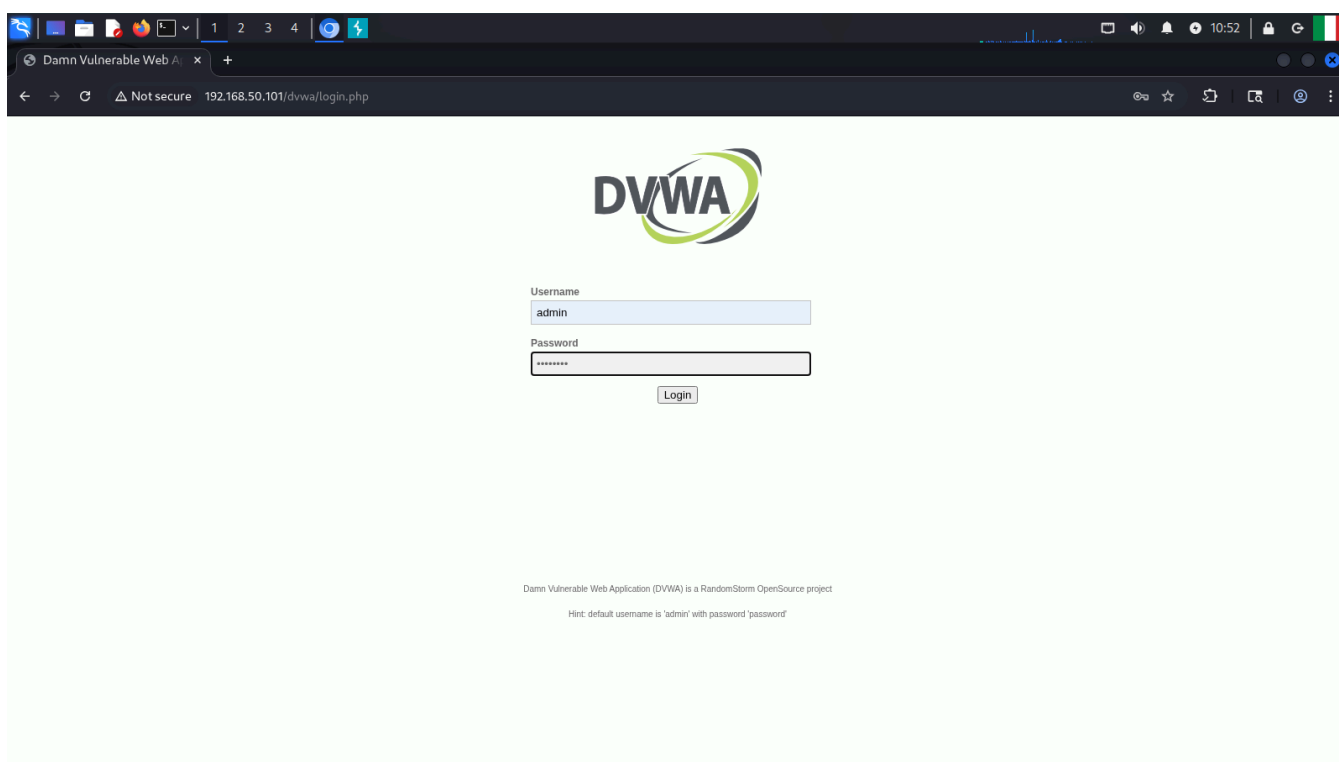
Appena avviata l'applicazione, ci sposteremo sul tab proxy, che è il tab principale da cui opereremo.



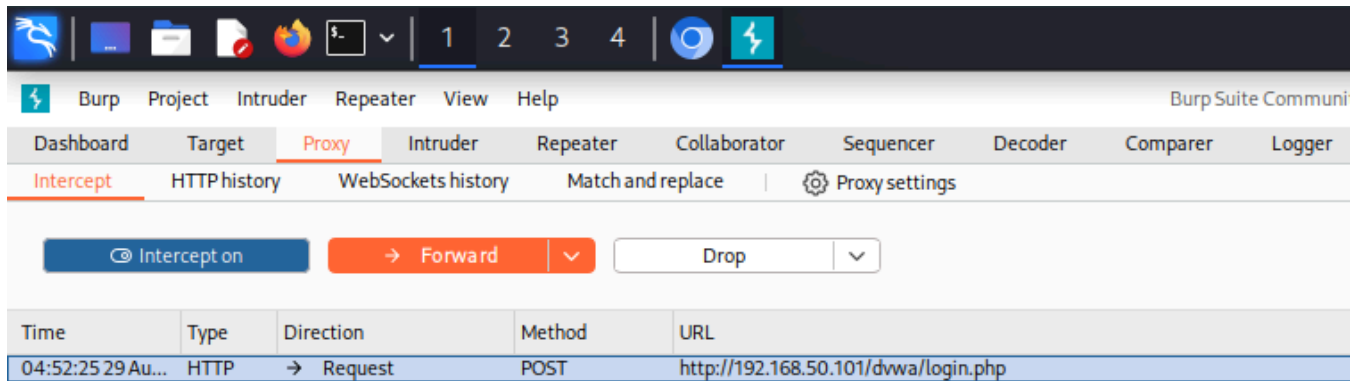
Una volta nella scheda Proxy avremo la possibilità di avviare l'intercettazione del traffico e lanciare il browser di default di Burp, da cui potremo navigare verso la nostra webapp.



Seguiamo gli step nell'immagine sopra e ci ritroveremo con chrome avviato.



una volta aperta la pagina della dvwa ci verrà chiesto di fare il login, inseriremo quindi username (*admin*) e password (*password*) e tornati su burp vedremo che la richiesta è visibile in chiaro e aspetta solo che la facciamo passare, tramite il tasto **Forward**, per essere eseguita sul browser.



Quì possiamo analizzare ed eventualmente modificare la richiesta appena inviata tramite il nostro browser. Si notano in chiaro username e password.

Request

Pretty
Raw
Hex

```

1 POST /dvwa/login.php HTTP/1.1
2 Host: 192.168.50.101
3 Content-Length: 44
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://192.168.50.101
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8
11 Referer: http://192.168.50.101/dvwa/login.php
12 Accept-Encoding: gzip, deflate, br
13 Cookie: security=high; PHPSESSID=f9602e6a7b1485e263b133c96c921b83
14 Connection: keep-alive
15
16 username=admin&password=password&Login=Login

```

?
⚙
⏪
⏩

Event log
All issues

Prima di far passare la richiesta col tasto **Forward**, clicchiamo col tasto destro e inviamo la stessa richiesta al tab **Repeater**, dove potremo simularla cambiandone i valori senza inviarla al browser.

The screenshot shows the Burp Suite Repeater tab. The Request pane displays a POST request to `/dwva/login.php` with the following details:

- Host: 192.168.50.101
- Content-Length: 44
- Cache-Control: max-age=0
- Accept-Language: en-US,en;q=0.9
- Origin: http://192.168.50.101
- Content-Type: application/x-www-form-urlencoded
- Upgrade-Insecure-Requests: 1
- User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36
- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
- Referer: http://192.168.50.101/dwva/login.php
- Accept-Encoding: gzip, deflate, br
- Cookie: security=high; PHPSESSID=09fada7f5d8d83555ddb142b8a066f58
- Connection: keep-alive

The Request body contains the following data:

```
username=admin&password=password&Login=Login
```

The Response pane shows the server's response, which includes a welcome message and a list of navigation links. The Inspector pane on the right shows the request and response details.

Nella scheda Repeater accanto al tasto arancione **Send** abbiamo un tasto col simbolo della ruota dentata che ci permette di cambiare alcune impostazioni, tra cui il **Follow Redirect**, che una volta attivato, ci permette di visualizzare le risposte del server ogni volta che simuliamo l'invio.

In questa scheda possiamo provare a cambiare i valori di invio della richiesta, inserendo uno username o password diversi, o modificando altri valori dell'header della richiesta e vedremo nella sezione **Response** la risposta che ci darebbe il server.

Se invece torniamo sul tab Proxy e mandiamo in Forward la richiesta fatta in precedenza nel browser, vedremo che saremo autenticati nella sessione che avevamo aperto sul browser, e questa non andrà ad intaccare le modifiche fatte nel tab Repeater.

The screenshot shows the Damn Vulnerable Web App (DVWA) interface. The page title is "Welcome to Damn Vulnerable Web App!". The page content includes a navigation menu on the left, a main content area with a warning and disclaimer, and a login form at the bottom.

The navigation menu includes the following links:

- Home
- Instructions
- Setup
- Brute Force
- Command Execution
- CSRF
- File Inclusion
- SQL Injection
- SQL Injection (Blind)
- Upload
- XSS reflected
- XSS stored
- DVWA Security
- PHP Info
- About
- Logout

The main content area displays the following text:

Welcome to Damn Vulnerable Web App!

Damn Vulnerable Web App (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goals are to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and aid teachers/students to teach/learn web application security in a class room environment.

WARNING!

Damn Vulnerable Web App is damn vulnerable! Do not upload it to your hosting provider's public html folder or any internet facing web server as it will be compromised. We recommend downloading and installing **KAMP** onto a local machine inside your LAN which is used solely for testing.

Disclaimer

We do not take responsibility for the way in which any one uses this application. We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

General Instructions

The help button allows you to view hits/tips for each vulnerability and for each security level on their respective page.

The login form at the bottom shows the following text:

You have logged in as 'admin'

Username: admin
Security Level: high
PHPIDS: disabled

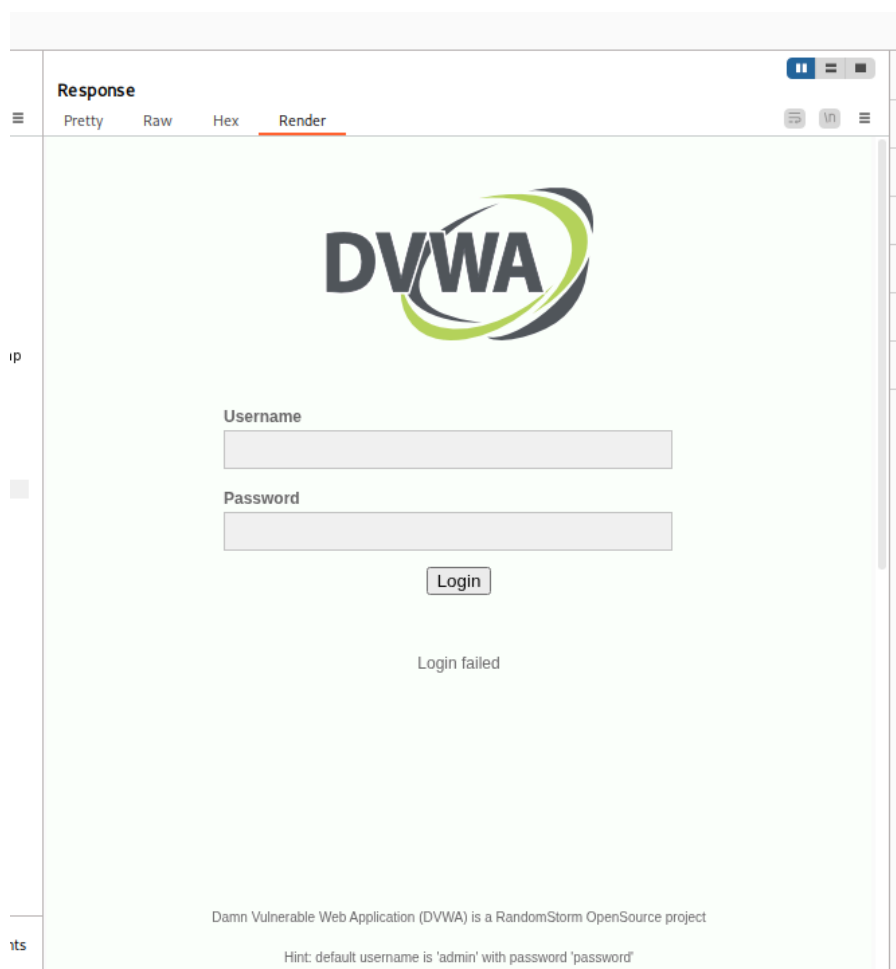
The footer of the page reads: "Damn Vulnerable Web Application (DVWA) v1.0.7".

A questo punto possiamo tornare nel tab repeater e provare ad inviare la nostra richiesta di login modificandola per testarne gli effetti:

```
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,
ng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: https://www.google.com
Accept-Encoding: gzip, deflate, br
Cookie: security=low; PHPSESSID=675708621f72b263f8152ef05ecd601e
Connection: close

username=admin&password=lolz.gay&Login=Login
```

e avremo come risultato che la pagina non ci farà entrare



Quello che abbiamo visto è solo un esempio delle potenzialità del software, che ci permette di testare numerosi aspetti delle webapp alla ricerca di vulnerabilità.

Alla prossima.

A handwritten signature in black ink, which appears to read 'Danilo Macri'.